

Firestore Collection Structure & Security Rules

MIT ACT — Crennotech Group Project (SiteChat) · Week 4 · Individual task · 15 August 2026

Proposed collections

Collection	Purpose	Key fields
sites	One document per CleanTasker Site	siteId, siteName, authorisedUserIds
sites/{siteId}/messages	Messages for that Site's chat room	senderId, text, timestamp, type (user/system), attachments, reactions, editedAt, deletedAt
sites/{siteId}/members	Who can access this Site's chat	userId, role (cleaner/supervisor/manager/client), joinedAt
users	Basic user profile info synced from CleanTasker auth	userId, displayName, deviceTokens (for push notifications)

Security rules — key principles

- A user can only read or write messages in a Site's chat room if their userId appears in that Site's members subcollection.
- Only Cloud Functions (server-side, using admin privileges) can create system messages — regular users cannot post as "system".
- Users can edit or delete only their own messages, never someone else's.
- Attachment uploads are restricted to authenticated, site-authorised users, with file-type and size checks in Cloud Storage rules.
- Membership (sites/{siteId}/members) is managed only by CleanTasker's backend via Cloud Functions — never editable directly by end users.

Multi-tenant safety

Since many different cleaning companies use CleanTasker, security rules must guarantee one company's staff can never see another company's Site chats. This is enforced by checking Site membership on every read/write, not just at login — so even a valid, authenticated user is blocked from Sites they don't belong to.